

AWS EC2 SSH Brute Force & Privilege Escalation Investigation

Portfolio Project 1

AWS EC2 SSH Brute Force & Privilege Escalation Investigation

Security Operations Center Investigation Report

Prepared By: Aromolaran Emmanuel

Role: SOC Analyst

Date: June 2025

Classification: Internal Security Investigation

Executive Summary

A security investigation was conducted following suspicious authentication activity detected on an AWS EC2 Linux instance. Analysis of Linux authentication logs identified a brute force attack originating from an external IP address. The attack resulted in successful compromise of the root account, followed by privilege escalation activities, credential access attempts, and the creation of a rogue administrative user. The investigation successfully reconstructed the attack timeline, identified indicators of compromise (IOCs), and produced containment and remediation recommendations.

Risk Rating: CRITICAL

Incident Status: Confirmed Security Incident

Investigation Outcome: Unauthorized access successfully achieved by attacker.

Business Impact Assessment

Confidentiality: High Impact – Potential exposure of password hashes, service account credentials, and internal system information.

Integrity: High Impact – Unauthorized account creation and privilege modification.

Availability: Medium Impact – Potential service disruption, ransomware deployment, or resource exhaustion.

Financial Impact: Incident response, infrastructure recovery, and security review costs.

Reputational Impact: Successful compromise could damage customer trust and organizational reputation.

Scope

Target Asset: AWS EC2 Instance (ip-172-31-35-28)

Operating System: Linux

Data Sources

- Linux auth.log
- Splunk Enterprise
- System authentication events

Tools Used

- Splunk Enterprise
- Linux auth.log
- MITRE ATT&CK;
- Threat Intelligence Sources

Investigation Methodology

NIST 800-61 Lifecycle: Identification, Analysis, Containment Planning, Recovery Planning, Lessons

Learned.

Technical Findings

Finding 1 – SSH Brute Force Activity

Source IP: 65.2.161.68

Targeted Accounts: root, admin, backup, server_admin

MITRE ATT&CK;: T1110 – Brute Force

Finding 2 – Successful Root Authentication

Time: 06:31:40 and 06:32:44

Account: root

MITRE ATT&CK;: T1078 – Valid Accounts

Finding 3 – Rogue User Creation

Time: 06:34:18

Commands: groupadd cyberjunkie, useradd cyberjunkie

MITRE ATT&CK;: T1136 – Create Account

Finding 4 – Privilege Escalation

Time: 06:35:15

Command: usermod

MITRE ATT&CK;: T1098 – Account Manipulation

Finding 5 – Credential Access Attempt

Time: 06:37:57

Command: sudo cat /etc/shadow

MITRE ATT&CK;: T1003.008 – OS Credential Dumping

Finding 6 – Post-Exploitation Enumeration

Time: 06:39:38

URL: raw.githubusercontent.com/montysecurity/linper/main/linper.sh

Method: curl

MITRE ATT&CK;: T1588 – Obtain Capabilities

Detection & Investigation Queries

Failed SSH Authentication Attempts:

```
index=linux "Failed password" | rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)" | stats count by src_ip,user
```

Successful Root Logins:

```
index=linux "Accepted password" | search user=root
```

Account Creation Activity:

```
index=linux ("useradd" OR "groupadd")
```

Sudo Privilege Assignment:

```
index=linux "usermod"
```

Credential Access Activity:

```
index=linux "/etc/shadow"
```

Post-Exploitation Downloads:

```
index=linux "curl"
```

Attack Timeline

06:31:40 – Root Login

06:32:44 – Additional Root Login

06:34:18 – Group Created

06:34:18 – User Created
06:35:15 – User Added To sudo
06:37:57 – /etc/shadow Accessed
06:39:38 – linper.sh Downloaded

Indicators of Compromise

IP Address: 65.2.161.68
URL: raw.githubusercontent.com/montysecurity/linper/main/linper.sh
User Account: cyberjunkie

Root Cause Analysis

Primary Cause: Weak authentication controls enabled successful brute force authentication.
Contributing Factors: Root SSH access enabled, No MFA, No account lockout controls, No Fail2Ban implementation.

Compliance & Governance Impact

NIST CSF: Protect, Detect, Respond
ISO 27001: Access Control, Identity Management, Logging & Monitoring
CIS Controls: Account Management, Access Control Management, Continuous Monitoring
NDPA (Nigeria): Potential breach assessment requirements.

Risk Assessment

SSH Brute Force – Critical
Root Compromise – Critical
Account Creation – Critical
Credential Access – Critical

Detection Opportunities

1. Multiple failed SSH logins from a single IP within 5 minutes
2. Successful root login following repeated failures
3. New Linux user creation
4. Addition of accounts to sudo group
5. Access to /etc/shadow
6. External downloads via curl or wget

Containment Recommendations

Immediate: Block source IP, disable cyberjunkie account, remove group, terminate active sessions.
Short-Term: Rotate credentials, review SSH keys, cron jobs, startup services.
Strategic: Disable root login, enforce MFA, deploy Fail2Ban, centralize logging, enhance monitoring.

Security Control Improvements

Identity Security: MFA, strong passwords, disable root SSH.
Preventive Controls: Fail2Ban, Security Group restrictions, AWS Systems Manager.
Detective Controls: CloudTrail, GuardDuty, SIEM monitoring.
Response Controls: SSH brute force playbooks and automated blocking.

Business Continuity Impact

Potential outcomes include service outages, customer data exposure, regulatory investigations, and extended recovery operations. Business continuity risk assessed as HIGH.

Incident Metrics

Detection Source: Splunk Alert Investigation
Time To Detect: Immediate
Time To Triage: 15 Minutes
Time To Investigate: 45 Minutes

Severity: Critical
Confidence Level: 95%

Lessons Learned

Weak authentication controls can result in full system compromise. Layered defensive controls would significantly reduce future risk.

Skills Demonstrated

Splunk Enterprise, Linux Security Monitoring, Threat Hunting, MITRE ATT&CK; Mapping, IOC Analysis, Timeline Reconstruction, Incident Response, Security Reporting, Risk Assessment, Compliance Mapping.

Executive Conclusion

The investigation confirmed a successful SSH brute force attack against an AWS EC2 instance, resulting in root-level compromise and post-exploitation activity. The attacker authenticated through credential guessing, created a privileged account, attempted credential access, and downloaded additional tooling for further exploitation. Recommended controls will significantly reduce the likelihood and impact of future compromise attempts.

Investigation conducted and documented by:

Aromolaran Emmanuel
SOC Analyst